10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Specialization:

Governance Risk and Compliance

Business Focus:

Data Privacy, Information Security and Compliance Readiness

Skill Outcome:

- Apply GDPR principles to real-world personal data processing activities.
- Assess information security controls against relevant SOC 2 Trust Services Criteria.

PAYGO FINANCIAL TECHNOLOGIES LTD

GDPR Data Mapping & SOC 2 Readiness Assessment

Project Learning Opportunities:

- Identify personal data, data subjects, processing activities, systems, external recipients and retention periods from a business scenario.
- Document personal data flows using a structured data inventory and written descriptions.
- Assess specified GDPR obligations against available scenario evidence.
- Evaluate information security controls against relevant SOC 2 Trust Services Criteria.
- Develop risk-based corrective actions and a prioritised remediation plan.

Tools Used:

10Alytics | ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Company Introduction

PayGo Financial Technologies Ltd. is a fictional fintech company headquartered in Dublin, Ireland. It provides a digital payment platform for individuals and small businesses across Ireland and other EU countries. The company has 120 employees and relies on cloud infrastructure and external providers for payment processing, identity verification, customer support, payroll and email communications.

Management wants to strengthen PayGo's data privacy and information security practices and prepare for a potential SOC 2 examination.

Current Situation: The following information describes PayGo's existing processing activities, documented practices and identified evidence limitations. Your assessment must be based on these facts.

A. Data Processing Environment: PayGo processes personal data through the following activities:

Activity	Data Processed	System/Recipient
Customer registration	Full Name, email address, phone number, residential address, date of birth	PayGo web and mobile applications
Identity verification	Name, date of birth, address, identity document details, verification result	Identity verification provider
Payment processing	Transaction reference, amount, currency, date, status, payer and recipient account identifiers	PayGo payment platform and database
Customer support	Customer name, contact details, ticket description, screenshots or attachments submitted by customers	Customer support ticketing system
Employee administration	Employee name, contact details, job title, department, payroll details	Human Resources system
Security monitoring	User account identifier, login time, IP address, authentication result, relevant system events	Central logging platform
Card Payments	Payment token, card brand, last four digits of the card number, transaction authorisation result	External payment processor

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Current Situation

PayGo does not store full payment card numbers or card verification codes in its application database. Its external payment processor handles the card details required to complete card transactions.

B. Privacy and Data Retention - PayGo has a documented retention schedule:

Data Category	Retention Period
Customer account information	While the account is active and for five years after closure
Transaction records	Seven years
Identity verification records	Five years after account closure
Customer support tickets	Three years after ticket closure
Employee records	Six years after employment ends
Security logs	Twelve months

However:

- PayGo has not documented the justification for every retention period.
- Deletion has not been tested across all systems and external providers.
- Its privacy notice does not clearly identify every category of recipient or explain all applicable retention periods.
- Its records of processing activities are incomplete.

10Alytics | ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Current Situation

C. Information Security Controls

PayGo has policies covering access management, incident response, change management, backup and recovery, and vendor management.

The following evidence limitations have been identified:

- Some system permissions have not been mapped to approved job roles.
- Completed periodic access reviews are missing for the customer support system and central logging platform.
- Multi-factor authentication (MFA) coverage across all in-scope systems has not been documented.
- Security monitoring records do not establish that all critical alerts are reviewed within defined timeframes.
- Incident response procedures have not been tested during the past twelve months.
- Backup restoration testing has not been evidenced.
- Change records do not consistently demonstrate approval and testing before deployment.

D. Third-Party Risk Management

PayGo maintains a vendor register and signed agreements with its cloud hosting, payment processing, identity verification, customer support, payroll and email providers.

However, provider records do not consistently identify:

- Data protection roles.
- Processing locations.
- Applicable international transfer arrangements.
- Recent security risk assessments.

Documented risk assessments and ongoing monitoring are incomplete for some providers.

D. SOC-2 Readiness

PayGo proposes to assess its payment platform and supporting infrastructure against three SOC 2 Trust Services Categories:

- Security: Protection against unauthorised access and security threats.
- Availability: Reliable access to the platform in line with service commitments.
- Confidentiality: Protection of information designated as confidential.

PayGo has not undergone a SOC 2 examination and has not established a central evidence register linking its controls to the relevant criteria.

10Alytics | ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

The Business Problem

PayGo's management needs to understand how personal data is collected, used, stored, shared and deleted. It also needs to identify where its documented privacy practices and available evidence require improvement under the GDPR.

At the same time, management wants to determine whether its information security controls are adequately designed, implemented and evidenced in preparation for a potential SOC 2 examination.

Management requires an initial assessment that identifies:

- Confirmed privacy and security weaknesses.
- Areas where available evidence is insufficient to reach a conclusion.
- Potential risks and business implications.
- Practical, prioritised corrective actions.
- The evidence needed to demonstrate that improvements have been completed.

Your Role

You are a Junior GRC Analyst assigned to PayGo's privacy and security improvement project.

Your responsibility is to conduct an initial GDPR Data Mapping exercise and SOC 2 Readiness Assessment using the information provided in this case study.

You are expected to:

- Create a data inventory and map personal data flows.
- Assess applicable GDPR requirements.
- Identify privacy, data governance, and information security gaps.
- Evaluate existing controls and available evidence against relevant SOC 2 criteria.
- Recommend practical remediation measures.
- Prepare a prioritised improvement plan for management.

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Your Task

As a Junior GRC Analyst, you are required to conduct an initial GDPR Data Mapping and Gap Assessment and a SOC 2 Readiness Assessment using the case study. Your assessment must address the following three parts.

Part A: GDPR Data Mapping and Gap Assessment

Task 1: Prepare a data inventory

Using the processing activities in the case study, prepare a table identifying, where the information is available:

Processing activity, Personal data categories, Data subjects, Processing purpose, System used, External recipient, where identified, Applicable retention period, and any material information that remains unspecified.

Task 2: Document personal data flows

For each processing activity, provide a short written description of the personal data flow, covering the relevant stages of collection, use, storage, sharing and deletion.

Use a table with the following columns:

Processing Activity	Data Source	System or Recipient	Storage or retention information	Deletion Practice or Evidence Gap

10Alytics | ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Your Task

Task 3: Assess applicable GDPR requirements

Assess the following requirements to the extent relevant to the case study:

- Lawfulness, fairness and transparency.
- Lawful basis for processing.
- Purpose limitation and data minimisation.
- Accuracy and storage limitation.
- Records of processing activities.
- Data protection roles and processor relationships.
- Security of personal data.
- Data subject rights and the arrangements for responding to requests.
- Personal data breach procedures.
- International transfers of personal data, where applicable.

For each requirement, identify the relevant GDPR provision where appropriate, explain what the requirement means for PayGo, and assess the evidence available.

Task 4: Prepare a GDPR gap assessment: Prepare a table containing:

Requirement	Evidence	Assessment Status	Potential Risk	Recommended Action

Use the following assessment statuses:
Confirmed gap: The scenario expressly establishes a deficiency. | Evidence gap: The available information is insufficient to verify the practice or requirement.| No gap established: The available facts do not establish a deficiency in the area assessed.

10Alytics | ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Your Task

PART B: SOC 2 Readiness Assessment

Task 1: Identify relevant Trust Services Criteria

Assess the relevance of the Security, Availability and Confidentiality categories selected by PayGo.
Identify relevant Trust Services Criteria using your course materials and explain how they relate to PayGo's payment platform and supporting infrastructure.

Task 2: Assess the existing controls

Evaluate the following control areas:
Access management and permissions, Multi-factor authentication, Security monitoring and alert review, Incident response, Change management, Backup and recovery, and Third-party risk management.

For each control area, document:

- The control or policy described in the scenario.
- The available evidence or evidence limitation.
- Whether a confirmed weakness or unresolved evidence gap exists.
- The relevant Trust Services Category or criterion.
- The potential risk.
- The recommended corrective action.

10Alytics | ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Your Task

Task 3: Prepare a SOC 2 evidence register

Prepare an evidence register identifying the evidence needed to assess PayGo's controls.

Your register should include:

Control Area	Evidence Required	Status	Purpose of the evidence

Part C: Integrated Gap Analysis and Remediation Plan

Consolidate the material findings from Parts A and B into a single remediation plan.

For each finding, include:
Finding and supporting scenario evidence, Relevant GDPR requirement and/or SOC 2 criterion, Assessment status, Potential risk or business impact, Recommended corrective action, Priority: High, Medium or Low, Proposed responsible department or role, Evidence required to demonstrate completion.

You may propose responsibilities for roles such as Compliance, Data Protection, Information Security, IT Operations, Human Resources or Vendor Management. Clearly present these as proposed assignments rather than facts about PayGo's existing organisational structure.

Prioritise actions according to the significance of the identified weakness, the sensitivity of the information involved, the potential impact and the urgency of obtaining missing evidence.

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

PROJECT DELIVERABLES

Submit one professional report containing the following four deliverables:

Deliverable 1: GDPR Data Mapping Report
A structured data inventory and written descriptions of personal data flows, including identified information gaps.

Deliverable 2: GDPR Gap Assessment
An assessment of the specified GDPR requirements, supported by scenario facts, assessment statuses, potential risks and recommendations.

Deliverable 3: SOC 2 Readiness Report
An assessment of relevant Trust Services Criteria and the specified control areas, together with an evidence register.

Deliverable 4: Integrated Gap Analysis and Remediation Plan
A consolidated, prioritised action plan identifying proposed responsibilities and the evidence needed to demonstrate completion.

PROJECT WORKFLOW

10Alytics

ACTD

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Phase 1: Understand the business and define the scope
Review PayGo's business activities, processing environment, third-party relationships and proposed SOC 2 scope.
Expected output: Business and assessment scope summary.

Phase 2: Map personal data
Prepare the data inventory and written descriptions of the data flows using the information provided.
Expected output: GDPR data inventory and data-flow table.

Phase 3: Conduct the GDPR gap assessment
Assess the specified GDPR requirements, document findings and identify unresolved evidence gaps.
Expected output: GDPR gap assessment matrix.

Phase 4: Conduct the SOC 2 readiness assessment
Review the selected Trust Services Categories and assess the specified controls and supporting evidence.
Expected output: SOC 2 readiness assessment and evidence register.

Phase 5: Integrate findings and prioritise remediation
Consolidate the findings, assign proposed priorities and responsibilities, and identify the evidence required for corrective actions.
Expected output: Integrated gap analysis and remediation plan.

Phase 6: Finalise the report
Review the report for accuracy, consistency, clear evidence references and appropriate distinctions between established deficiencies and unresolved questions.
Expected output: Final capstone report.

Project Workflow

10Alytics

ACCREDITED BY THE AMERICAN COUNCIL OF TRAINING AND DEVELOPMENT

Step 1	Understand the Business
Step 2	Map Personal Data and Assess GDPR Gaps
Step 3	Assess SOC 2 Readiness
Step 4	Integrate findings and prioritise remediation
Step 5	Submit Final Report.

Conclusion

This capstone project demonstrates how a structured, evidence-based approach to GDPR and SOC 2 can strengthen an organisation's data privacy practices, information security controls, and audit readiness. By applying data mapping, gap analysis, and risk-based remediation, students gain practical insight into how GRC professionals help organisations like PayGo improve regulatory accountability, protect personal data, and prepare for an independent SOC 2 examination.